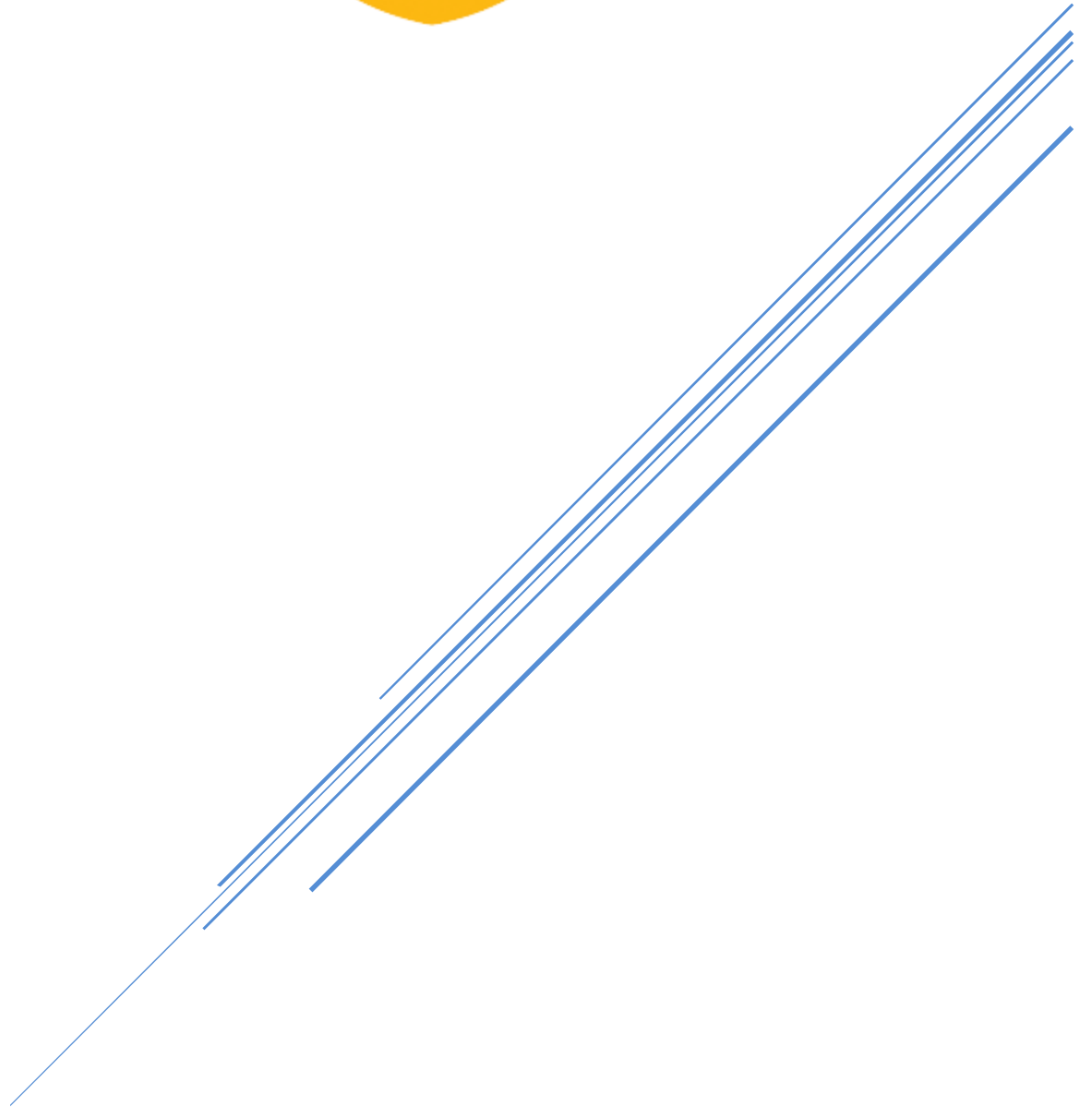


SAS821S SECURITY ANALYTICS — LAB 2



Student Details: Marshall Mwandingi 215103238

A1. Initial Triage and Competing Hypotheses

https://github.com/mwandingim/215103238_Mwandingi_SAS821S_Lab2.git

After considering the evidence, I feel that the activity is more of an actual security incident than normal user behavior. The main concerns include unauthorised access, abnormal account activity, and the potential compromise of organisational sensitive data. At this juncture, I would consider the situation to be at high-risk since restricted systems/data might have been accessed, stolen, changed, or transferred prior to containment being completed. The key considerations here include determining if the activity is a security incident or not, isolation of affected accounts/endpoints, suspending/reviewing access rights, and informing management/legal/incident response teams. To determine them, I would look into the following data sources for correlation in order to identify the source, timing, scope, and motive of the activity.

Competing Hypotheses

Hypothesis 1: Malicious insider activity. One of the scenarios of the activity being malicious insider activity is where an employee/contractor misuses their access to view/change/remove/copy sensitive information. It would be more likely in cases where the activity takes place using a normal corporate device/from an expected location using valid credentials but still not showing any business purpose. Other indicators for this include unusual downloads, attempts to cover tracks, or the activity taking place around resignation, disciplinary process, or change in role. On the other hand, a weak indication of this scenario would include the activity involving unknown infrastructure, impossible travel, execution of malware, and login activity which does not match the user.

Hypothesis 2: Compromised account. Another scenario and the most likely one is where an external party obtains the credentials of the user (possibly through phishing) and uses them to blend in with normal internal activity. Indicators of this include logins from unusual countries/IPs, repeated failed attempts followed by successful login, irregular activity on the VPN, appearance of a new device/browser fingerprint, suspicious mailbox rules, phishing emails, or activity outside the working hours of the user. On the other hand, the lack of unusual activity, lack of phishing, credential theft, malware and command-and-control activities would make this explanation weak.

Hypothesis 3: Benign administrative or operational activity. Another possible scenario is where the activity is beginning in nature and linked to normal business operations such as maintenance, user support, preparation of an audit, or data migration. Indicators of this scenario include the existence of change record, purposeful and business-related activity, activity during regular times, use of recognised administrative tools/supplied support accounts, and normal activity for the user's role. On the other hand, the non-existence of a change record, lack of business purpose, unusual timing, unnecessary access to sensitive data, violation of policy, and activity hiding would weaken this scenario.

A2. Security-Intelligence Collection Plan

Mapping of the datasets provided to the intelligence cycle helps in defining a purpose for each data source in the investigation. Moreover, it also makes the analysis easier to understand since the evidence would be tied to direction, collection, processing, analysis, dissemination, and feedback instead of separate data sources.

Intelligence Cycle Evidence Mapping

Intelligence Cycle Phase	Application to the Investigation	Supplied Evidence
Direction	Define the intelligence requirement, determine whether the activity represents account compromise, insider activity or legitimate remote access, identify the affected user and endpoint, show whether restricted KYC information was accessed or exfiltrated, establish the attack timeline and identify security control failures.	ofs_employee_directory.csv; ofs_asset_inventory.csv; ofs_access_policy_matrix.csv;
Collection	Collect evidence relevant to identity, authentication, endpoint activity, data access, network transfers and external threat indicators.	ofs_email_gateway_logs.csv; ofs_vpn_authentication_logs.csv; ofs_endpoint_process_logs.csv; ofs_file_access_logs.csv; ofs_proxy_dlp_logs.csv; ofs_threat_intelligence.csv; ofs_access_session_investigation.csv; ofs_access_session_training.csv
Processing	Preserve and validate the supplied evidence, verify SHA-256 hashes, describe timestamps, standardise fields and identities, identify missing values and duplicates and derive behavioural variables such as off-hours activity, new-device use, large downloads or uploads and impossible travel.	All supplied CSV datasets; SHA256SUMS.txt; derived fields from the access-session, VPN, endpoint and proxy/DLP data
Analysis	Establish normal user and peer	ofs_access_session_training.csv;

	group behavior, compare investigation activity against historical baselines, apply the transparent access risk rule, train the supervised Random Forest model, relate events across logs and match indicators against threat intelligence.	ofs_access_session_investigation.csv; employee/asset/policy datasets; email/VPN/endpoint/file/proxy-DLP logs; ofs_threat_intelligence.csv
Dissemination	Communicate the intelligence findings to decision makers through the incident report and CISO security intelligence note. Report on the affected account and endpoint, attack sequence, evidence of KYC collection, attempted exfiltration, confidence level, model results and recommended response actions.	Correlated findings from all supplied datasets; top_15_high_risk_sessions.csv; model_metrics.csv; confusion_matrix.csv; incident timeline; threat-intelligence matches
Feedback	Use the findings to improve future collection and detection requirements. Feedback should include stronger phishing domain controls, endpoint execution monitoring, MFA or conditional access controls, restricted data access monitoring and DLP rules. Future monitoring should assess whether these improvements reduce similar incidents and false negatives.	Findings from email, endpoint, VPN, file-access, proxy/DLP and threat intelligence evidence, model or rule performance, observed control gaps

Source Classification

Source	Classification	Purpose
ofs_employee_directory.csv	Internal operational data	Identifies employees, roles, departments and account context.
ofs_asset_inventory.csv	Internal operational data	Identifies endpoints, ownership,

		criticality and security controls.
ofs_access_policy_matrix.csv	Internal operational data	Determines authorised roles, resources and access permissions.
ofs_email_gateway_logs.csv	Internal operational data	Provides evidence of email delivery, phishing indicators, URLs and attachments.
ofs_vpn_authentication_logs.csv	Internal operational data	Provides authentication, source-location, device and MFA evidence.
ofs_endpoint_process_logs.csv	Internal operational data	Provides endpoint process execution and malicious-process evidence.
ofs_file_access_logs.csv	Internal operational data	Shows file or resource access, including restricted KYC data.
ofs_proxy_dlp_logs.csv	Internal operational data	Shows network destinations, uploads or downloads and DLP decisions.
ofs_access_session_training.csv	Internal operational data	Provides historical labelled sessions for behavioural baselines and supervised ML.
ofs_access_session_investigation.csv	Internal operational data	Provides investigation period access-session behavior.
ofs_threat_intelligence.csv	External threat intelligence	Provides external indicators, confidence, tactics and recommended actions used to corroborate internal evidence.
Employee/asset/policy context	Contextual/business data	Provides organizational context needed to interpret whether activity is appropriate for a user's role, department or asset.

Quality and Implementation Risks

Accuracy: Logs or intelligence reports could be partial, inaccurate, duplicates, and incorrectly associated with any user or device. It is thus necessary that such indicator matches be verified through internal telemetry.

Timing: Threat intelligence, authentication logs, and other logs could be late in their arrival due to the activity having been performed. This might hamper the process of detection and containment of the current threat.

Access: Security logs and employee details could include operational and private information. Thus, access to them should be restricted to only those who are authorized to do so.

Privacy: Identity, authentication, and file access data for employees should be used only for investigation purposes and should not be disclosed unnecessarily.

Alerting: Too many alerts from behavioral rules and machine learning models can overwhelm security analysts and mask actual threats. It is thus essential that thresholds be correlated with other sources before any action is taken.

Evidence Integrity and Threat Intelligence Handling

Integrity of the evidence will be maintained through retention of the source files provided in their original state, the maintenance of separate analysis copies, recording of file hashes through the provided SHA256SUMS.txt, and logging of the process and transformation of the evidence during the analysis phase. Any derived datasets and analytics results will be clearly segregated from the original evidence.

Threat intelligence indicators will not be considered to constitute evidence of compromise. For instance, a match against a known malicious domain or IP address would be considered an indication that needs to be confirmed by internal evidence such as email delivery, endpoint execution, access to the organization's resources, VPN logon, file access and DLP/proxy server activity. The more independent internal sources can confirm the finding the higher level of confidence.

B1. Reproducible Data Preparation and Quality

Prior to performing the analysis I reviewed the main columns in the dataset and defined practical data types for each column in consideration of how the information in that field would be used. Fields containing identifiers, usernames, IP addresses, devices, locations, category fields and other identifiers have been left in text format to enable matching across the logs in the future. Event/session time is converted to datetime type, and download volume, upload volume, risk score – to numeric types. Additionally, I created binary indicator fields for the following behaviors: off-hours activity, weekend access, use of new device, access to new geography, impossible travel and privilege mismatch.

Field / Data Group	Data Type	Preparation / Use
Event and session IDs	String	Preserved as unique identifiers for traceability and correlation.
User or account, IP, device and geography	String	Normalised for identity, device and location comparisons.
Timestamp fields	Datetime	Converted to a consistent datetime format using Namibia local time (UTC+2).

Download/upload volume and risk scores	Numeric	Converted/handled as numeric values; transfer volumes expressed in MB where required.
Categorical fields	String / categorical	Used for role, department, resource and action comparisons.
Behavioural indicators	Binary / Boolean	Derived for off-hours, weekend, new device/geography, impossible travel and privilege mismatch.

Dataset	Rows	Columns	Missing Cells	Duplicate Rows
ofs_employee_directory.csv	24	11	0	0
ofs_asset_inventory.csv	16	7	0	0
ofs_access_policy_matrix.csv	9	5	0	0
ofs_email_gateway_logs.csv	433	16	425	0
ofs_vpn_authentication_logs.csv	317	13	311	0
ofs_endpoint_process_logs.csv	568	14	0	0
ofs_file_access_logs.csv	1114	14	0	0
ofs_proxy_dlp_logs.csv	477	15	473	0
ofs_threat_intelligence.csv	27	10	0	0
ofs_access_session_training.csv	3000	27	2699	0
ofs_access_session_investigation.csv	450	26	415	0

B2. Individual Baseline

Individual behavioral baseline of user mhaingura based on 117 historical access sessions is provided below.

Measure	Historical baseline	Investigation period
Sessions	117	Investigation period
Mean download (MB)	11.06	72.08
Mean upload (MB)	N/A	55.45
Sensitive-resource access/session	0.265	Materially elevated
New-device rate	4.3%	Elevated novelty signals
Off-hours rate	12.0%	Elevated investigation activity

Observation: In the investigation period, activity of user mhaingura has shown a clear deviation from the historical one. Most notable is an increased volume of data movement, which is indicated by more robust signals of using new device, unusual access patterns, and possibly privilege mismatch.

Operational significance: These deviations can be used to prioritise sessions for review, but cannot be taken as evidence on its own. I would cross-check against authentication, endpoint, file access and proxy/DLP information first.

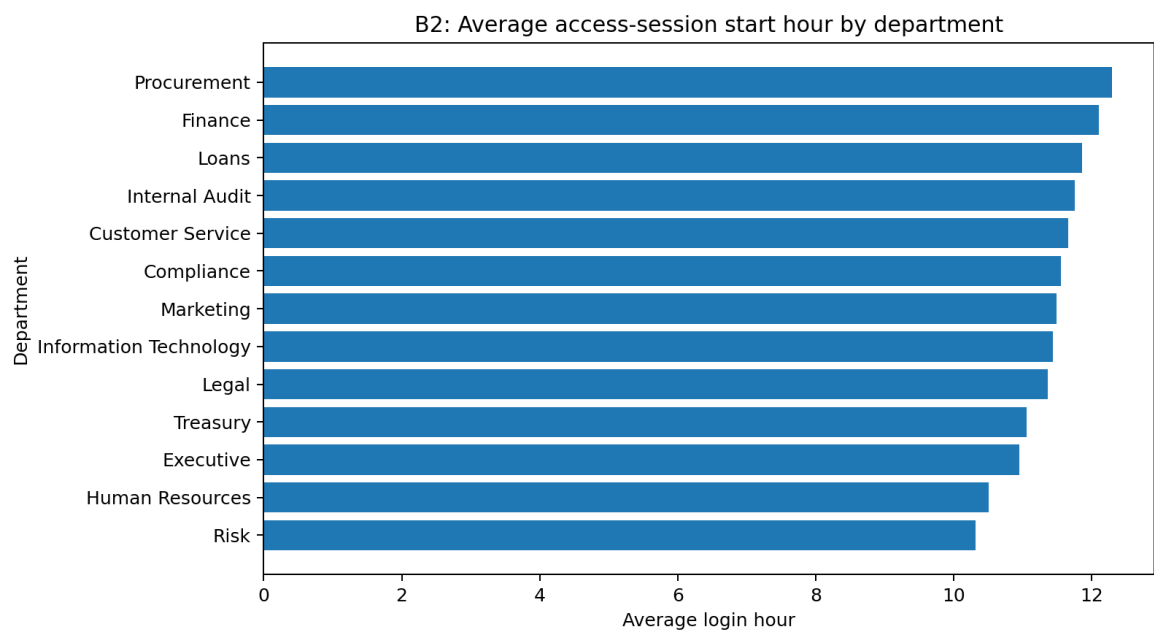
User and Peer-Group Baselines

Historically, there were 117 sessions for mhaingura. The Customer Service group has 724 sessions in the historical dataset.

The historical average download for mhaingura was 11.06 MB/session, whereas for the peer group, it is 10.83 MB/session. The historical sensitive resource access is also highly correlated at 0.265/0.261 per session. The historical new device rate was 4.3%/5.1% for mhaingura vs. the peer group, and the off-hours access rate was 12.0%/11.0%.

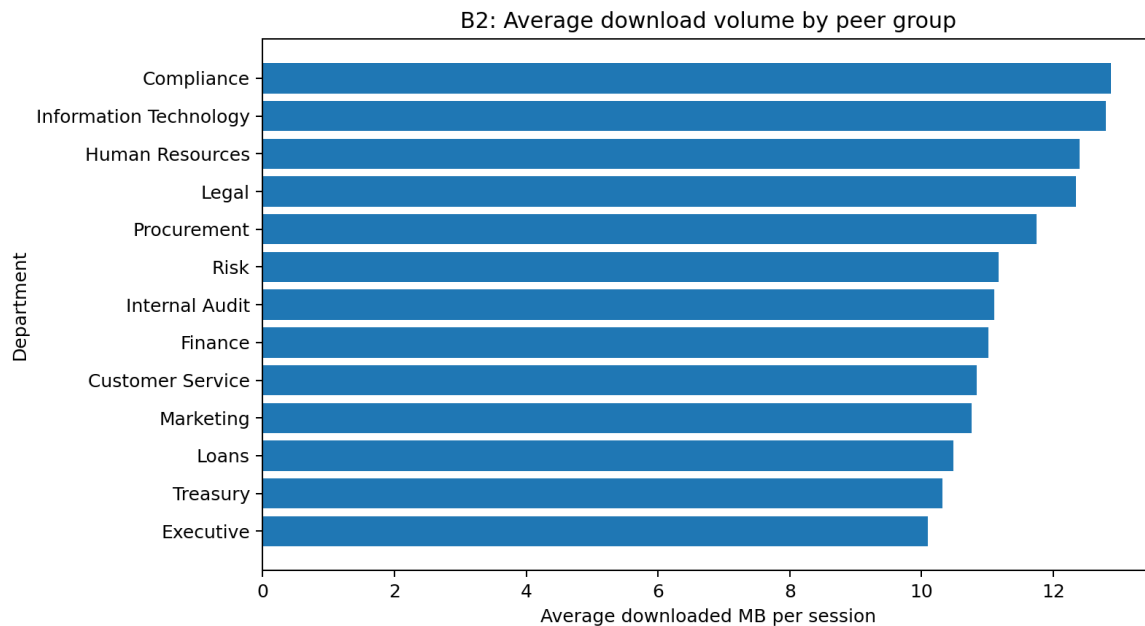
For the investigation period, mhaingura sessions had an average download of 72.08 MB and upload of 55.45 MB, with significantly higher novelty, impossible travel and privilege mis-match signals. Thus, the deviation that is strongest is the unusual device or geography, restricted resource access along with significant data movement, rather than just login time.

Figure 1. Average access session start hour by department



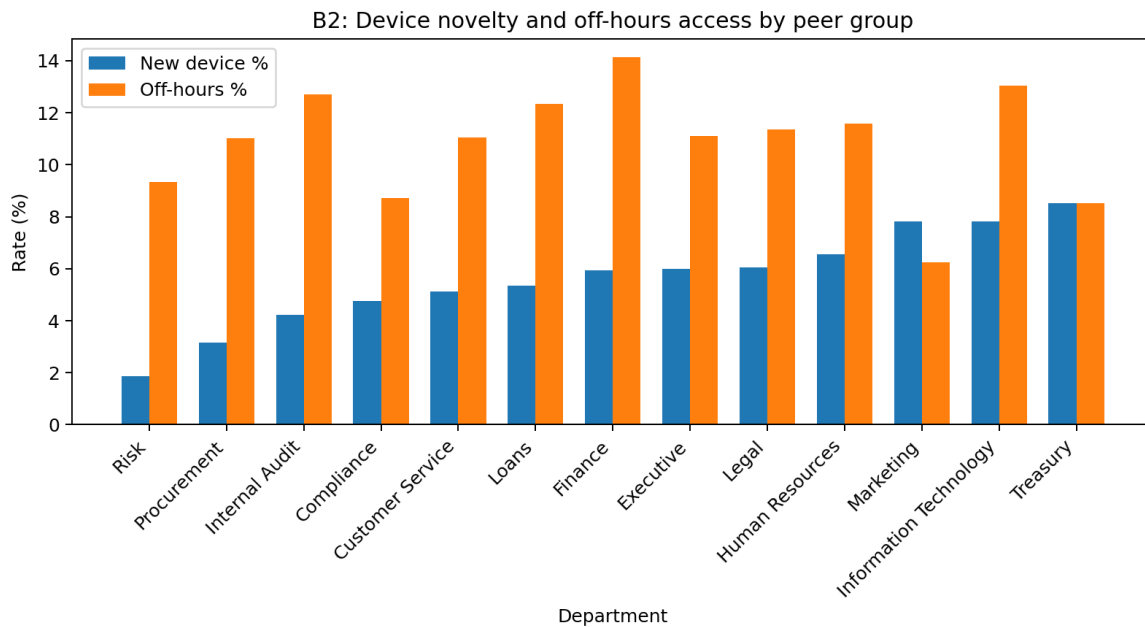
Question: How divergent are peer-group login times? Observation: department averages tend to be clustered around daytime access times. Significance: Time alone is a poor discriminator.

Figure 2. Average download volume by peer group



Question: Who downloads more – which peer groups? Observation: Differences in the baseline are relatively small. Significance: The restricted KYC gathering for this particular incident cannot be explained by a regular download volume.

Figure 3. Device novelty and off-hours access by peer group



Question: How often do new devices and off-hours sessions happen? Observation: Both are part of the normal pattern of behavior to some extent. Significance: They can help detect compromise, but do not prove anything on their own.

B3. Transparent Access-Risk Rule

Threshold is a mechanism that needs to be considered as such. High score indicates that this particular session should be investigated and evaluated in conjunction with the bigger picture before escalating.

Behaviors the rule will not capture: Slow and low attack that avoids detection by keeping within normal parameters – using known device and location, working during regular hours and downloading data in smaller portions.

False positive example: Authorized administrator might have legitimate reasons to move a large amount of data or access some information outside regular work hours.

False Positive and Missed behavior

Rank	Session ID	User	Rule score	Risk level
1	CASE-KYC-01	mhaingura	85.0	High
2	CASE-EXFIL-01	mhaingura	81.0	High
3	CASE-EXFIL-02	mhaingura	65.0	High
4	CASE-VPN-01	mhaingura	59.0	High
5	S00150	hamukwaya	29.0	Below threshold
6	S00414	nambala	28.0	Below threshold
7	S00278	katjiuongua	27.0	Below threshold
8	S00072	ntinda	26.0	Below threshold

9	S00118	nambala	23.0	Below threshold
10	S00093	shilongo	22.0	Below threshold

This rule has been applied to each investigation session. Sessions are sorted from highest to lowest according to rule score, with ties being broken by rule flag count. Top 15 sessions flagged by the rule have been exported to top_15_rule_based_high_risk_sessions.csv.

High risk threshold score is 30. It is based on the real investigation session score distribution through the 90th percentile (15.00). Threshold score is rounded up to the closest 5, but is never below 30. As a result, 4 out of 450 investigation sessions exceeded the threshold.

Threshold and Rule-Based Ranking

Risk score is calculated as the total number of points assigned for each of the indicators triggered by a session. Maximum score can be 100.

Indicator	Points	Trigger
Off-hours activity	5	off_hours = 1
New device	8	new_device = 1
Failed logins	8	failed_logins_30m >= 2
MFA denials	7	mfa_denials >= 1
Sensitive resources	8	sensitive_resources >= 3
Denied accesses	4	denied_accesses >= 1
Large download	8	bytes_downloaded_mb >= 100
Large upload	15	data_upload_mb >= 100
Process risk	10	process_risk_score >= 70
Destination risk	7	destination_risk_score >= 50
Peer deviation	5	peer_deviation_score >= 5
Impossible travel	5	impossible_travel = 1
Privilege mismatch	10	privilege_mismatch = 1

Transparent Rule and Indicators

A clear rule based risk score calculation has been applied to all 450 investigation sessions. Rule makes use of 13 visible indicators with fixed weights, making it reproducible and comprehensible.

C1. Correlated Incident Timeline

Event ID	Timestamp	Evidence Source	Observed Action / Interpretation
E00305	2026-09-11 16:54:12	Email gateway	Suspicious benefits-review email from

			ofservices-portal.com delivered. Newly registered domain; gateway allowed it.
E00307	2026-09-11 17:01:44	Email gateway	Second benefits-review reminder delivered. Repeated phishing lure immediately before execution.
P00378	2026-09-11 17:02:07	Endpoint	Chrome opened the benefits-review URL. User interaction follows suspicious email.
P00379	2026-09-11 17:03:19	Endpoint	Unsigned mshta.exe executed remote update.hta. Strong execution indicator; TI-linked hash.
P00380	2026-09-11 17:03:44	Endpoint	Hidden PowerShell with encoded command executed. Strong compromise indicator.
P00381	2026-09-11 17:04:12	Endpoint	rundll32 executed wupdate.dat. Secondary execution consistent with malware.
V00222-V00225	2026-09-11 18:18:05–18:19:22	VPN	Four failed Johannesburg VPN attempts from new device WIN-CLIENT-8472. Repeated failures and MFA denials indicate credential misuse.
V00226	2026-09-11 18:20:11	VPN	Johannesburg login succeeded after MFA approval. Successful foreign access after failures.
V00227	2026-09-11 18:22:01	VPN	Windhoek login succeeded on corporate workstation. Two locations within minutes support impossible travel.
P00388	2026-09-11 18:25:33	Endpoint	net.exe queried Domain Admins. Discovery activity.
P00389	2026-09-11 18:26:09	Endpoint	nltest.exe queried domain controllers. Further

			discovery activity.
X00759	2026-09-11 18:33:42	File access	CUSTOMER_EXPORT listed. Role mismatch: officer lacks export permission.
X00760-X00795	2026-09-11 18:34:00–18:45:05	File access	Rapid bulk KYC export downloads succeeded. Restricted data collection.
P00395	2026-09-12 00:26:16	Endpoint	7z created kyc_q3.zip from KYC exports. Collection archived.
P00396	2026-09-12 00:35:44	Endpoint	Unsigned clone copied archive to remote storage. Exfiltration staging/tool use.
D00333	2026-09-12 00:36:12	Proxy/DLP	284.3 MB uploaded to cdn-storage-sync.net. High-confidence TI exfiltration indicator; first transfer allowed.
D00334	2026-09-12 00:43:51	Proxy/DLP	972.1 MB upload blocked. Later transfer contained.
D00335	2026-09-12 00:44:07	Proxy/DLP	22.4 MB upload blocked. Further exfiltration attempt contained.

C2. Evidence-Based Findings

Affected identity and endpoint: mhaingura and WKST-CS-017 (10.30.12.17), which is a Medium criticality Windows 11 Customer Service workstation equipped with CrowdStrike.

Initial Access: E00305 and E00307 were benefit review email messages sent by ofservices-portal.com. The gateway permitted this because the website had recently been registered and there was no block rule for it. P00378 indicates the opening of a URL followed by unsigned mshta and hidden encoding of PowerShell and rundll32 in P00379-P00381.

Threat Intelligence: TI1001 associates the phishing domain with Mantis Jackal and TI1005 associates the malicious endpoint hash.

Authentication: V00222-V00225 show four unsuccessful Johannesburg VPN login attempts on a new device WIN-CLIENT-8472, with multiple MFA denial or timeout errors. V00226 passes with a successful MFA verification, followed by V00227 from Windhoek. This indicates a stronger case of credentials abuse rather than actual travel.

Privilege Escalation & Collection: Mhaingura is a Customer Service Officer and holds CRM_BASIC and CUSTOMER_BASIC permission level. CUSTOMER_EXPORT permission is available only to supervisors and

approved roles. X00759 denotes the export area, and X00760-X00795 indicate the bulk download of restricted KYC documents at an extremely fast rate.

Exfiltration **and** Archiving: P00395 creates kyc_q3.zip file and uses P00396 to transfer using unsigned rclone to remote storage. D00333 permits

Control weaknesses: Phishing domain control, endpoint execution control, VPN/new device/MFA control and DLP control let some components of attack chain pass.

C3. Incident Response and Confidence

Primary hypothesis: My hypothesis is that the most convincing explanation for the incident would be account and endpoint compromised after phishing email. And it seems that the incident proceeds further from the credential abuse to KYC data collection, archive creation and attempted exfiltration. I am confident in my conclusion as the described sequence is consistent with multiple types of evidence such as emails, VPN logs, endpoint logs, files accesses, DLP and threat intelligence.

Alternative hypothesis: malicious insider behavior assisted by control weaknesses is also plausible but it seems to be less likely scenario compared to account and endpoint compromise. In particular, sequence of the phishing and malware, as well as the use of new foreign device, speak in favor of external compromise. The evidence provided here does not prove involvement of employee into the incident.

Immediate containment actions: Disable or reset affected credentials, terminate active sessions/tokens; isolate WKST-CS-017; block threat intelligence indicators and malicious hash; collect evidence on endpoints, accounts, emails, VPNs, file accesses and DLPs.

Recommendations for future actions: Improve phishing domain reputation/age control, constrain execution of mshta, encoded powershell and unsigned programs; apply stronger phishing resistant MFA/conditional access; improve DLP on export restrictions.

D1–D2. Machine-Learning Access Detection

The problem involves supervised learning since the 3,000 historical access sessions have known outcomes either normal or suspicious. The model includes behavioral and contextual features such as time, novelty of the device, authentication friction, sensitivity of resources, amount of data, risk of the process and destination, peer deviation, impossible travel and privilege mismatch.

Random Forest classifier was used in this case. With a stratified 70/30 train/test split and a random seed of 42 the classifier resulted in 2,100 training sessions and 900 test sessions.

Metric	Result
Accuracy	0.910
Precision	0.724
Recall	0.632
F1-score	0.675

False-negative rate	0.368
---------------------	-------

Accuracy is 91.0%, precision is 72.4%, recall is 63.2% and F1-score is 67.5%. The false negative rate is 36.8%. In case of compromise account detection, recall is crucial feature since the lack of identification could lead to the attack continuation. That is why I would not consider only the accuracy as a decisive factor although it looks very good.

Comparison of model and rules: CASE-KYC-01 is rated the best in both ways. This increases the significance of the main investigation session. CASE-EXFIL-01 and CASE-EXFIL-02 are also well-estimated in both approaches. CASE-VPN-01 has a high model rating and high rule rating. CASE-PHISH-01 provides a good comparison of two approaches, as the model identifies the risk at the behavioral stage whereas bigger collection or exfiltration signs are still not seen.

D2. Top 15 High-Risk Investigation Sessions

Session ID	Timestamp	User	Probability	Rule Score
CASE-KYC-01	2026-09-11 18:33:00	mhaingura	0.921	85
CASE-VPN-01	2026-09-11 18:18:00	mhaingura	0.864	59
S00232	2026-09-13 21:58:00	nambala	0.849	15
CASE-EXFIL-01	2026-09-12 00:35:00	mhaingura	0.839	81
CASE-EXFIL-02	2026-09-12 00:43:00	mhaingura	0.812	65
S00300	2026-09-12 13:16:00	ntinda	0.800	20
S00072	2026-09-13 17:40:00	ntinda	0.778	26
S00233	2026-09-09 05:32:00	tkamati	0.773	15
S00195	2026-09-12 11:39:00	mhaingura	0.742	15
S00223	2026-09-10 01:37:00	haufiku	0.726	12
S00427	2026-09-12 23:21:00	sihuhua	0.724	13
S00015	2026-09-12 01:12:00	haufiku	0.716	9
S00278	2026-09-08 08:51:00	katjiuongua	0.715	27
S00330	2026-09-07 06:33:00	katjiuongua	0.697	20
S00290	2026-09-08 05:54:00	nnakale	0.693	20

D3. Threat Intelligence and Adversarial Limitations

Threat intelligence confirms the internal findings, but I would not use it as the only proof. TI1001 is a match for the phishing domain, TI1002 is a match for the C2 IP, TI1003 and TI1004 are matches for the exfiltration destination, TI1005 is a match for the endpoint hash. They will be helpful when the internal findings are present, especially email, endpoint, VPN and DLP logs.

Evasion tactics might include slow transfers, smaller uploads, operation during working hours, reuse of already existing devices, use of multiple destinations, behavioural mimicry, poisoned historical data, and model drift. Mitigations against these might include improved cross-source correlations, periodic drift detection and re-training, protected training data and validation, and threat intelligence with an evaluation of source confidence, indicator age, and multiple sources.

E1. Security Intelligence Note to the CISO

To: Chief Information Security Officer, Omatako Financial Services

Subject: High-confidence account compromise and attempted KYC exfiltration — mhaingura / WKST-CS-017

Conclusion and confidence: I conclude with high confidence that the mhaingura account and WKST-CS-017 were compromised following the benefits-review phishing e-mail on 11 September. This is demonstrated through a clear timeline of malicious execution on endpoint, foreign authentication using the VPN, KYC data gathering, creation of archive, and transfer attempt.

Information Assets affected: CUSTOMER_EXPORT/KYC data on FS-KYC-01, endpoint WKST-CS-017 and mhaingura identity. Damage includes restricted data gathering and archiving, 284.3 MB of upload traffic being allowed, and two further attempts for 972.1 MB and 22.4 MB being blocked.

Immediate actions: Firstly, isolate the impacted system and de-authorize the user's credentials. Secondly, preserve all evidence on the system, accounts, email, VPN, and DLP. Thirdly, block the identified IOCs and malicious hash, and apply deny/quarantine restrictions for restricted bulk export uploads. I will also analyze other systems/accounts for this IOC in order to find out whether there were any other incidents.

Outstanding intelligence gap: whether the MFA approval was compromised using social engineering and what data is stored in the kyc_q3.zip archive.

Measureable control improvement goal: reduce mean time from high-risk phishing IOC detection to quarantine less than 5 minutes; all restricted CUSTOMER_EXPORT access by unauthorized roles should generate blocking alert prior to transferring data.